SOC Simulation Lab

Project Documentation: Planning & Management, Literature Review and Requirements Gathering

A shared Elastic-based SOC simulation lab in which a team runs ATT&CK-mapped attack scenarios against instrumented systems and works the resulting alerts through a documented investigation workflow.

Item	Detail
Team	Zero-day Noobs
Program	Digital Egypt Pioneers Initiative (DEPI), Round 5, Cyber Security Incident Response Analyst track
Repository	https://github.com/Zero-day-Noobs/soc-simulation-lab
Version	1.0, 15 October 2026

Team members

#	Name	Role
1	Amira Ahmed Ibrahim Alaidi	Project lead and documentation
2	Eslam Ramadan Heshmat Abdelhamid	Infrastructure and platform
3	Nada Hamdy Abdelazim Mahmoud	Detection engineering
4	Reem Elsayed Ahmed Yousef Ahmed	Attack simulation and investigation lead
5	Aya Ezzat Mohamed Kame Wazir	Threat intelligence and automation

---

Part 1: Project Planning & Management

1.1 Project Proposal

Overview

The project builds a Security Operations Center (SOC) simulation lab around one core capability: investigation. A team of five executes attack scenarios mapped to MITRE ATT&CK against instrumented systems, collects the resulting telemetry in a shared Elastic SIEM, and works the alerts it raises from triage to a closed, documented case. Detection rules, dashboards, endpoint detection and response (EDR), a lightweight threat intelligence (CTI) integration and one automated response playbook support that workflow.

Problem statement

Detection engineering and incident investigation are practical disciplines: skill grows through repeated work on realistic telemetry and honest review of what was missed. Commercial SOC platforms are costly, and most self-built labs are single-machine builds that a distributed team cannot share, review together or rebuild reliably. The result is limited hands-on practice with the full alert-to-case lifecycle.

Objectives

1. Provide one team-accessible Elastic SIEM (Elasticsearch, Kibana and Fleet) reachable only through a private network.
2. Instrument a representative environment: Windows client, Windows Server with Active Directory, Linux host and a deliberately vulnerable web application, each reporting through Elastic Agent with Sysmon and Elastic Defend where applicable.
3. Execute end-to-end attack scenarios mapped to MITRE ATT&CK, using Atomic Red Team and manual attacker tooling.
4. Engineer detection rules and dashboards, and measure coverage per technique, documenting what is missed as carefully as what is caught.
5. Run a SOC-style investigation workflow in which alerts are assigned, investigated with Kibana Timeline, documented in cases and closed with a verdict and ATT&CK mapping.
6. Demonstrate one CTI enrichment flow and one automated playbook, scoped deliberately so that detection and investigation quality come first.
7. Keep the environment reproducible: deployment definitions, configurations and rules are version-controlled in Git.
8. Build team capability in detection engineering, incident investigation and secure infrastructure operations through applied practice, with every scenario closed by a written report.

Scope

In scope

- Elastic SIEM (Elasticsearch, Kibana, Fleet Server) on a hosted VPS, reachable over a private network
- Windows client, Windows Server domain controller, Linux host and a vulnerable web application as log sources
- Sysmon, Elastic Agent and Elastic Defend as the endpoint telemetry and EDR layer
- Attack simulation with Atomic Red Team and manual tooling from a Kali Linux attacker host
- Detection rules mapped to ATT&CK and per-scenario dashboards
- Alert assignment and case management in Kibana across the five team members
- One CTI enrichment flow (OpenCTI or Elastic threat intelligence feeds, decided in Week 5)
- One SOAR playbook in Shuffle

Out of scope

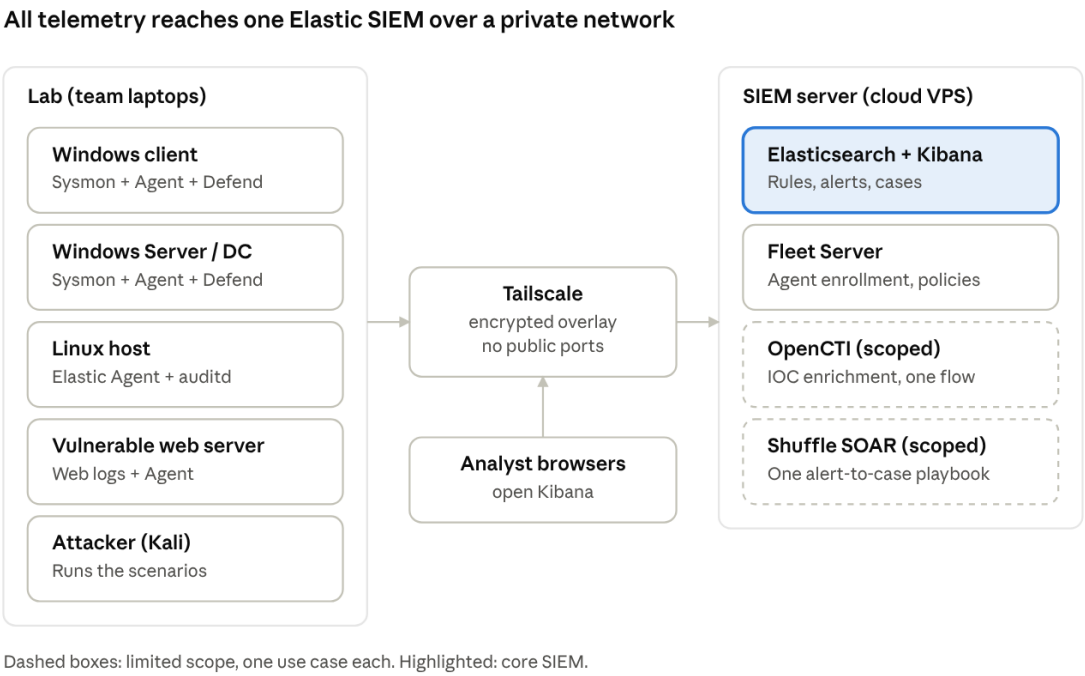
- Commercial licenses or products
- Automated active response (for example blocking IPs or isolating hosts)
- Machine-learning or behavioral anomaly detection
- Production-grade high availability and capacity engineering

Deliverables

- This documentation set, followed by the design, implementation and final reports required by DEPI
- Public GitHub repository with Docker Compose definitions, configurations, detection rules, playbook and README
- Detection coverage report per ATT&CK technique, including misses
- Complete investigation case reports
- Final presentation and demonstration of the working lab

1.2 Solution Architecture

Telemetry from every lab host reaches a single Elastic SIEM over a private network, and the whole team investigates it through Kibana in the browser.



architecture · lab hosts, private network, SIEM server

Endpoints send telemetry through Elastic Agent and Fleet Server pushes policies back. Analysts reach Kibana through the same private network, and the dashed CTI and SOAR components stay deliberately narrow.

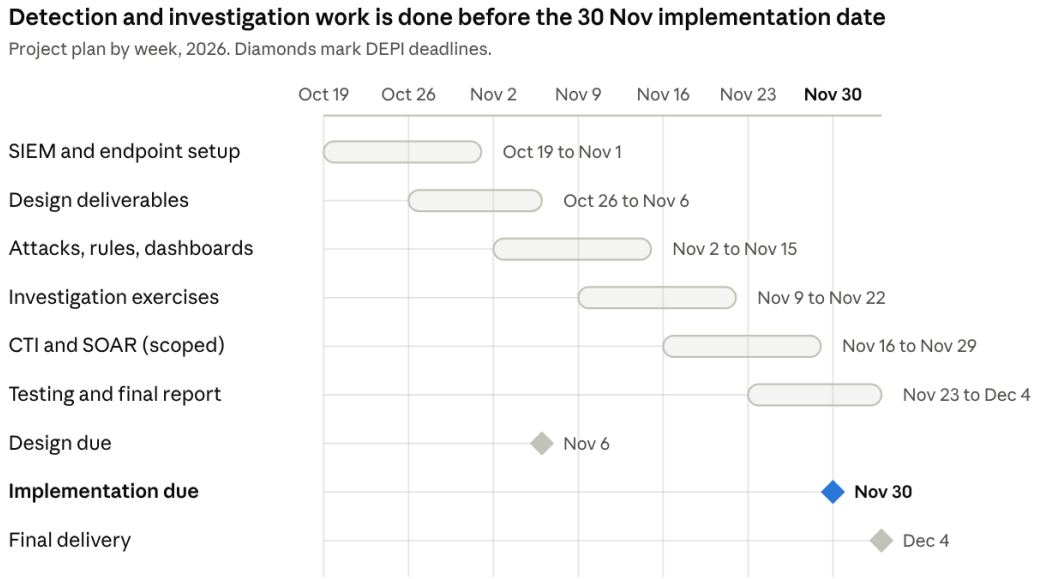
Design decisions

Decision	Rationale
One hosted SIEM node: cloud VPS in an EU region, Ubuntu 24.04 LTS, Docker Compose	Shared access for a distributed team at any hour; the full environment is defined in version-controlled files and can be rebuilt on any provider

Decision	Rationale
Private overlay network (Tailscale) for all traffic	No SIEM port is exposed to the public internet; endpoints, analysts and the server share one encrypted network
Elastic Agent managed by Fleet instead of standalone beats	One agent per host, centrally managed policies, and Elastic Defend EDR on the same agent
One virtual machine per team laptop (8 GB RAM each)	Realistic multi-host scenarios without hosting Windows workloads in the cloud; every VM joins the same private network
Live malware, if ever used, confined to an isolated host-only network with a single-port log relay	The shared lab and the SIEM never share a network with live samples
CTI and SOAR limited to one flow each	Keeps engineering effort on detection quality and investigation, the project's core outcomes

1.3 Project Plan

The plan runs six work packages over seven weeks and reaches each DEPI deadline with a working increment: foundation first, then attacks and detections, then investigation, with CTI and SOAR last.



timeline · six work packages, three DEPI deadlines

Work packages overlap deliberately: investigation exercises begin while the last detection rules are tuned, and CTI and SOAR start only once detections are stable.

Delivery gates

Gate	Date	Exit criteria
G1 Foundation	1 Nov 2026	All lab hosts report to the SIEM; at least one detection rule fires on a simulated technique
G2 Detection and investigation	15 Nov 2026	Two scenarios executed, rules and dashboards cover their techniques, the first case is closed with a verdict
G3 Enrichment and automation	29 Nov 2026	One CTI enrichment flow and one playbook demonstrated end to end, investigation reports complete

Resource plan

Resource	Plan
SIEM host	Cloud VPS in an EU data center: 6 vCPU, 12 GB RAM, 100 GB NVMe, Ubuntu 24.04 LTS, shared by the team
Lab endpoints	One VM per team laptop (8 GB RAM each): Windows client, Windows Server with Active Directory (evaluation edition), Linux host and Kali attacker
Vulnerable web application	Containerized DVWA or OWASP Juice Shop on a Linux VM, reachable only over the private network
Networking	Tailscale (WireGuard-based) for every host and analyst, no SIEM port exposed publicly
Software	Elastic Stack (Basic license), Sysmon, Atomic Red Team, OpenCTI or Elastic threat intelligence feeds, Shuffle
Source control	GitHub Organization Zero-day-Noobs, public repository, MIT license
Coordination	Weekly team review, task tracking in GitHub Issues, Git branches with pull requests

1.4 Task Assignment & Roles

The team works as one unit: all five members take part in every phase, from building and attacking to detecting, investigating and documenting. Each area has one lead who is accountable for its delivery and quality, and a backup who can operate it. Scenario and case-review responsibilities rotate so every member practices the full workflow.

Role	Responsibilities	Lead	Backup	Participation

Role	Responsibilities	Lead	Backup	Participation
Project lead and documentation	Planning, DEPI coordination, documentation, quality review of case reports	Amira	Eslam	
Infrastructure and platform	SIEM host, private network, Docker Compose deployment, snapshots, access management	Eslam	Nada	All members
Detection engineering	Sysmon and agent policies, detection rules, dashboards, ATT&CK coverage tracking	Nada	Reem	All members
Attack simulation and investigation lead	Scenario design, Atomic Red Team execution, vulnerable web application, case workflow	Reem	Aya	All members
Threat intelligence and automation	CTI enrichment flow, Shuffle playbook, integration with Kibana cases	Aya	Amira	All members

1.5 Risk Assessment & Mitigation Plan

ID	Risk	Likelihood	Impact	Mitigation
R1	SIEM host unavailable or hosting cost grows	Low	High	Single low-cost VPS, snapshot before each scenario, full environment rebuildable from Git on any provider
R2	8 GB laptops cannot run the full lab	High	Medium	One VM per laptop, start only the machines a scenario needs, Windows Server in Core mode where possible
R3	SIEM exposed to the internet	Medium	High	No public ports; access only through the private network, authentication on every service
R4	Secrets committed to the public repository	Medium	High	`.env` files ignored by Git, `.env.example` with empty values, review before each push, rotate any exposed secret immediately
R5	Scope grows beyond the available time	High	High	Delivery gates; CTI and SOAR limited to one flow each, investigation quality is the priority

ID	Risk	Likelihood	Impact	Mitigation
R6	Live malware reaches shared systems	Low	High	No live malware in the shared lab, any sample analysis stays in an isolated host-only network with a single-port log relay
R7	Licensing or plan limits block a feature	Medium	Medium	Verify Elastic Basic features and private network user limits in Week 1; alternatives identified (WireGuard, Elastic threat intelligence feeds)
R8	Coordination across a remote team slips	Medium	Medium	Weekly review, task tracking in GitHub, branches and pull requests for shared files
R9	A member becomes unavailable	Medium	Medium	Second owner for every component; setup steps documented in the repository
R10	Lab data lost or a disk fills	Medium	Medium	Snapshots before deletion, manual log retention, disk usage watched against Elasticsearch watermarks

1.6 Key Performance Indicators (KPIs)

Targets are proposed and will be confirmed after the first scenario provides a baseline.

KPI	Measurement	Target
Log source coverage	Planned lab hosts reporting to the SIEM	100%
Ingestion delay	Time from event on a host to visibility in Kibana	Under 60 seconds
Detection coverage	ATT&CK techniques executed that raise an alert	At least 10 techniques executed, at least 70% detected, every miss documented
Investigation completion	Scenario alerts triaged with a verdict and closed in a case	100% of alerts in two or more scenarios
Triage time	Median time from alert to verdict per scenario	Baseline from scenario 1, lower in scenario 2
False positives	Alerts raised by normal activity in a baseline run	Documented and tuned to an agreed threshold
Platform availability	SIEM uptime during planned lab hours	At least 95%

KPI	Measurement	Target
	and demonstrations	
Reproducibility	Time to rebuild the SIEM from the repository on a fresh server	Under 2 hours
CTI enrichment	Alerts enriched through the CTI flow	At least one working end-to-end flow
Automation	SOAR playbook from alert to case and notification	At least one playbook, under 2 minutes end to end
Documentation	Phase deliverables submitted on time	100%

Part 2: Literature Review

2.1 Background

A SOC monitors an organization's systems, detects suspicious activity and coordinates the response. Five technologies carry most of that work, and this project uses each at a scale a small team can operate:

- **SIEM** (Security Information and Event Management): centralizes logs, correlates events and raises alerts.
- **EDR** (Endpoint Detection and Response): records detailed endpoint behavior and detects or blocks malicious activity on the host.
- **CTI** (Cyber Threat Intelligence): adds context to an indicator, such as the actor, campaign and techniques behind it.
- **SOAR** (Security Orchestration, Automation and Response): executes repetitive triage and response steps as playbooks.
- **Case management**: records an investigation's evidence, timeline and verdict.

Three shared references shape the work. **MITRE ATT&CK** is a public knowledge base of adversary tactics and techniques that gives detection work a common vocabulary and lets coverage be measured per technique. **STIX** is the standard language for describing threat intelligence, and it is the data model behind OpenCTI. **Sigma** is a vendor-neutral format for writing detection rules that can be converted for different SIEMs.

2.2 Technologies Reviewed

Area	Technology	Role in this project
SIEM and analytics	Elastic Stack (Elasticsearch, Kibana, Fleet)	Log storage and search, detection rules, alert queue, cases, dashboards

Area	Technology	Role in this project
Endpoint telemetry	Sysmon, Windows event logs, Linux auditd	Process, network, file and registry events that the operating system does not record in detail by default
EDR	Elastic Defend on Elastic Agent	Deep endpoint telemetry, behavior-based detection and prevention
Attack simulation	Atomic Red Team	Small tests, each mapped to one ATT&CK technique, used to trigger and measure detections
Vulnerable target	DVWA or OWASP Juice Shop	Deliberately vulnerable web application for a web-to-host attack chain
Threat intelligence	OpenCTI, or Elastic threat intelligence integrations	Indicator context for alert enrichment
SOAR	Shuffle	Workflow automation for one alert-to-case playbook
Private networking	Tailscale (WireGuard-based)	Encrypted connectivity between hosts, analysts and the SIEM without public ports
Deployment	Docker, Docker Compose, Git	Reproducible environment defined in version-controlled text files

2.3 Related Platforms and Labs

Reference	What it offers	Difference from this project
Security Onion	Full open-source platform for network monitoring, log management and threat hunting	Integrated product; the project builds and documents each integration deliberately
Wazuh	Open-source XDR and SIEM with agents, rules and compliance modules	Different stack from the Elastic ecosystem used here
HELK (Hunting ELK)	ELK-based threat hunting platform	Focused on hunting; no case workflow, CTI or SOAR integration
DetectionLab	Automated lab with a Windows domain and security tooling	Built for local deployment on one powerful host, not for a distributed team
SOC training platforms and datasets (for	Pre-built alert-triage scenarios	Hosted content to practice on, this project builds the environment and the scenarios themselves

Reference	What it offers	Difference from this project
example guided SOC simulations and Boss of the SOC data)		

2.4 Gap and Contribution

Existing labs are either complete products that hide the integration work, or local builds that need strong hardware and cannot be shared across a remote team. This project contributes:

1. A **shared, remotely accessible** SOC environment sized for a small team.
2. An **end-to-end chain** in one place: telemetry, attack simulation, detection, investigation, enrichment and automated response.
3. A **repeatable** build, defined in Docker Compose and Git, that survives a change of provider.
4. **Public documentation and case reports** that others can follow and reuse.

2.5 Feedback, Evaluation and Improvements

Item	Entry
Feedback and evaluation	
Suggested improvements	Integrate AI into the SOC pipeline, using machine-learning anomaly detection and AI-assisted alert triage within the SOAR playbook to speed up investigation and reduce false positives.
Final grading criteria	

Team-proposed future enhancements

- AI integration in the SOC workflow: machine-learning anomaly detection on collected logs to complement rule-based detections.
- AI-assisted alert triage inside the SOAR playbook: summarize the alert, add CTI context and suggest a priority and next action, with the analyst approving the decision.
- Additional playbooks and log sources, and a library of Sigma rules converted for Elastic.

2.6 References

Access dates are recorded in the final report.

- MITRE ATT&CK, https://attack.mitre.org
- Elastic documentation, https://www.elastic.co/docs
- Elastic detection rules repository, https://github.com/elastic/detection-rules
- Atomic Red Team, https://atomicredteam.io
- Sigma rules, https://sigmahq.io
- OpenCTI documentation, https://docs.opencti.io
- Shuffle, https://shuffler.io

- Tailscale documentation, https://tailscale.com/kb
- Sysmon, Microsoft Sysinternals documentation, https://learn.microsoft.com/sysinternals
- DVWA, https://github.com/digininja/DVWA
- Security Onion, https://securityonionsolutions.com; Wazuh, https://wazuh.com; HELK, https://github.com/Cyb3rWard0g/HELK; DetectionLab, https://github.com/clong/DetectionLab

---

Part 3: Requirements Gathering

3.1 Stakeholder Analysis

Stakeholder	Interest and needs	Influence
DEPI coordinator and lecturer	Complete, timely documentation and a working demonstration, evaluates the project	High
Project team	Shared access, clear roles and a reproducible environment, also the SOC analysts within the simulation	High
Mentors and instructors	Technically sound design and correct use of security tooling	Medium
SOC analyst (simulated primary user)	Searchable logs, trustworthy alerts, timeline, cases, enrichment and automation	High
Open-source community and future learners	Documentation, rules and scenarios they can reuse	Low
Employers and recruiters	Evidence of practical SOC work in the public repository	Low

3.2 User Stories & Use Cases

User stories

ID	As a...	I want to...	So that...
US-01	SOC analyst	pick up an unassigned alert and assign it to myself	the team never duplicates work
US-02	SOC analyst	search and filter logs from every host in one place	I can investigate without logging into each machine
US-03	SOC analyst	follow an attack across hosts on a timeline	I can reconstruct what happened and in what order

ID	As a...	I want to...	So that...
US-04	SOC analyst	record evidence, ATT&CK techniques and a verdict in a case	the investigation can be reviewed and reported
US-05	SOC analyst	see enrichment for an IP, domain or hash inside the alert	I can judge severity faster
US-06	SOC analyst	have a playbook create the case and notify the team	repetitive steps are handled consistently
US-07	Detection engineer	run a simulated technique and see whether it is detected	I can measure and improve coverage
US-08	Team member	open Kibana from any location through the private network	we all work on the same environment remotely
US-09	Infrastructure engineer	rebuild the SIEM from the repository	we recover quickly after a failure or a provider change
US-10	Coordinator	read the documentation and watch a demonstration	I can evaluate the project

Use cases

ID	Use case	Actor	Main flow	Result
UC-01	Collect and search telemetry	SOC analyst	Agents send events to the SIEM, the analyst searches in Discover	Events visible within 60 seconds
UC-02	Run an attack scenario	Detection engineer	Execute scenario steps on lab hosts, rules evaluate the telemetry	Alerts, plus a record of detected and missed techniques
UC-03	Investigate an alert	SOC analyst	Assign the alert, pivot in Timeline, attach it to a case	Evidence and a verdict recorded
UC-04	Close a case	SOC analyst	Complete the closure template: verdict, ATT&CK mapping, timeline, recommendation	Reviewed case report
UC-05	Enrich an indicator	SOC analyst or playbook	Alert indicator is checked against the CTI source	Context shown with the alert
UC-06	Automated response	SOAR platform	Alert triggers the playbook: enrich, create case, notify	Case and notification

ID	Use case	Actor	Main flow	Result
				created
UC-07	Access the environment	Team member	Join the private network and sign in with a personal Kibana account	Authorized access only
UC-08	Rebuild the environment	Infrastructure engineer	Clone the repository, set secrets, start with Docker Compose, restore a snapshot	Working SIEM on a new server

3.3 Functional Requirements

ID	Requirement	Priority
FR-01	The system shall provide one Elastic SIEM accessible to all team members.	Must
FR-02	The system shall enroll every lab host with Elastic Agent managed through Fleet.	Must
FR-03	The system shall collect Sysmon and Windows event logs from the Windows client and the Windows Server domain controller.	Must
FR-04	The system shall collect system, authentication and auditd logs from at least one Linux host.	Must
FR-05	The lab shall include a Windows Active Directory domain with a domain controller.	Should
FR-06	The lab shall include a deliberately vulnerable web application whose web server logs are ingested.	Should
FR-07	The system shall run Elastic Defend on the Windows endpoints and surface its alerts in Kibana Security.	Should
FR-08	The system shall support repeatable attack scenarios mapped to MITRE ATT&CK, using Atomic Red Team and manual tooling.	Must
FR-09	The system shall provide detection rules covering the scenario techniques, tuned against a baseline of normal activity.	Must
FR-10	The system shall provide dashboards per scenario: event timeline, alert volume and ATT&CK coverage.	Must
FR-11	The system shall support an alert workflow: triage, assignment to a team member, status and closure with a verdict.	Must
FR-12	The system shall support cases that hold evidence, a timeline, ATT&CK mapping and a closure summary.	Must

ID	Requirement	Priority
FR-13	The system shall provide a personal account and role for each team member.	Must
FR-14	The system shall preserve scenario data through snapshots so scenarios can be reviewed and replayed.	Should
FR-15	The system shall enrich alerts through one CTI flow (OpenCTI or Elastic threat intelligence feeds).	Could
FR-16	The system shall run one SOAR playbook that enriches an alert, creates a case and notifies the team.	Could
FR-17	All hosts and analysts shall connect through a private encrypted network.	Must
FR-18	The deployment shall be defined as code (Docker Compose and configuration) in Git.	Must

3.4 Non-Functional Requirements

ID	Category	Requirement
NFR-01	Security	No SIEM service is reachable from the public internet; access requires the private network and authentication.
NFR-02	Security	Secrets are never committed to the repository; exposed secrets are rotated immediately.
NFR-03	Safety	Attack simulation runs only against systems the team owns; live malware is excluded from the shared network.
NFR-04	Performance	Events are visible in Kibana within 60 seconds under normal lab load.
NFR-05	Resource efficiency	The lab runs one VM per 8 GB laptop, and the SIEM runs within a 12 GB host (Elasticsearch heap limited to 4 GB).
NFR-06	Availability	The SIEM is available at least 95% of planned lab hours and demonstrations.
NFR-07	Reproducibility	The SIEM can be rebuilt from the repository and a snapshot in under 2 hours.
NFR-08	Maintainability	Configuration is modular, one folder per component, with consistent naming.
NFR-09	Portability	The deployment does not depend on a single hosting provider.

ID	Category	Requirement
NFR-10	Usability	The README lets a new member reach Kibana and run a scenario without assistance.
NFR-11	Data lifecycle	Logs are retained until deliberately removed, with a snapshot taken first and disk usage monitored.

3.5 Assumptions and Constraints

- The team has five members working remotely, each with a laptop of 8 GB RAM.
- Software is limited to open-source or free-tier editions; the only recurring cost is the shared SIEM host.
- Plan limits (private network users, Elastic Basic features) are verified in Week 1, with alternatives identified.
- All deliverables are published on GitHub by the DEPI deadlines in Section 1.3.

Prepared by Team Zero-day Noobs. This document is stored in the project repository under `docs/` and is updated at each phase.